

Mapeamento de Ameaças + adequação à LGPD

Descrição do Sistema / Projeto

O nosso projeto será uma loja pet shop online, com o objetivo de clientes fazerem as compras para seus animais de estimação, como ração, petiscos e brinquedos, que estão catalogados em nosso catálogo.

O sistema será acessado por navegador, e será necessário o cadastro na loja online para a entrega dos produtos, usando seu email e seu endereço para a entrega

o sistema irá armazenar as informações em um banco de dados, para possibilitar o controle dos pedidos.

Dados pessoais tratados

Nome completo: identificação do cliente no sistema.

E-mail: utilizado para login e comunicação com o cliente.

Senha: utilizada para acesso à conta do usuário (armazenada de forma segura).

Endereço completo: utilizado para realização das entregas dos produtos.

Políticas de acesso e identidade (IAM)

O sistema contará com gerenciamento de identidade e acesso (IAM) garantindo que cada usuário tenha acesso apenas as funcionalidades permitidas

O acesso será dividido por perfis como administrador e cliente com permissões diferentes

Regras para o uso do IAM

Senhas fortes

Regra: Senhas devem ter no mínimo 8 caracteres com letras, numeros e simbolos

Justificativa: Reduz o risco de ataques de força bruta e senhas fracas

Bloqueio após múltiplas tentativas

Regra: Bloquear login por 10 minutos após 5 tentativas incorretas

Justificativa: Impede ataques automatizados e força bruta

CAPTCHA no login

Regra: ativar CAPTCHA após tentativas repetidas de login

Justificativa: dificulta ataques feitos por bots

Autenticação de 2 fatores para administradores

Regra: Admin só entra com senha + códigos

Justificativa: Mesmo com senhas vazadas o invasor não acessa

Sessão expirada automaticamente

Regra: Logout automático após 15 minutos inativos

Justificativa: Reduz risco de roubo de sessão

Login apenas por HTTPS

Regra: Bloquear autenticação se o site não estiver em HTTPS

Justificativa: Evita interceptação de credenciais MITM

Cookies seguros

Regra: Cookies com HttpOnly e Secure ativados

Justificativa: Protege contra roubo de sessão por XSS

Redefinição de senhas via email confirmados

Regra: Reset de senha só por link temporário enviados ao email

Justificativa: Evita que terceiros alterem senhas sem autorização

Link de redefinição expira

Regra: Link de reset de senha expira em 10 minutos

Justificativa: Reduz risco de uso indevido caso o link seja interceptado

Confirmação de email no cadastro

Regra: Conta só ativa após confirmar o email

Justificativa: Reduz contas falsas e ataques automatizados

Perfis separados de clientes e administrador

Regra: Cada usuário pertence a um perfil

Justificativa: Garante controle de acesso e evita privilégios excessivos

Cliente não pode acessar painel administrativo

Regra: Rotas/admin bloqueados para usuários comuns

Justificativa: Impede invasões e acesso a dados internos

Administrador precisa de login específico

Regra: Painel admin exige autenticação separada

Justificativa: Dificulta ataques e melhora segurança do controle de acesso

Funcionário só acessar pedidos não dados sensíveis

Regra: Funcionário pode ver pedidos mas não pode ver senha ou dados completos

Justificativa: Aplica princípio do menor privilégio

Somente admin pode alterar preços

Regra: Alteração de preço só permitida para admin

Justificativa: Impede sabotagens ou erros de usuários comuns

Somente admin pode excluir produtos

Regra: Exclusão de itens do catálogo apenas por admin

Justificativa: Impede sabotagens ou erros de usuários comuns

Cliente só poderá ver seus próprios pedidos

Regra: Usuarios só acessaram pedidos vinculados ao seu ID

Justificativa: Evita vazamentos de dados de outros clientes

Cientes só poderão editar seus próprios endereços

Regra: Não pode alterar dados de outra conta

Justificativa: Garante privacidade e integridade dos dados

Acesso a relatórios só para administradores

Regra: Relatórios financeiros e estoque apenas para admin

Justificativa: Evita vazamentos de dados internos

Logs de ações administrativas obrigatórias

Regra: Registrar quem alterou produto, preço e pedidos

Justificativa: Garante auditoria e rastreabilidade útil para LGPD e segurança

Mapeamento de ameaças e Controles de segurança

Ameaça: Vazamentos de dados em banco de dados

Impacto: Exposições de informações pessoais

Medidas de segurança: Criptografia, firewall, backups e controle de acesso

Gravidade (G) 5

Urgência (U) 4

Tendência (T) 4

GUT = $G * U * T = 80$ (ameaça crítica)

Ameaça: Ataque de força bruta por login

Impacto: Invasão a contas de clientes

Medidas de segurança: Limite de tentativas

Gravidade (G) 4

Urgência (U) 4

Tendência (T) 3

GUT = $G * U * T = 48$ (ameaça alta)

Ameaça: Falha no servidor ou perda de dados
Impacto: Perda de informações de dados dos clientes
Medidas de segurança: Backups de segurança
Gravidade (G) 4
Urgência (U) 4
Tendência (T) 3
GUT = $G * U * T = 48$ (ameaça alta)

Ameaça: SQL Injection (injeção SQL)
Impacto: o invasor pode alterar ou apagar dados do banco de dados assim roubando informações pessoais dos clientes
Medidas: uso de firewall e monitoramento de acessos
Gravidade (G) 5
Urgência (U) 5
Tendência (T) 4
GUT = $G * U * T = 100$ (Ameaça Crítica)

Ameaça: Cross-Site Scripting (XSS)
Impacto: O invasor pode inserir scripts maliciosos no site fazendo com que scripts sejam executados no navegador de outros usuários isso pode causar roubo de sessão
Medidas: Validação e filtragem de dados inseridos pelo usuário
Gravidade (G) 4
Urgência (U) 4
Tendência (T) 4
GUT = $G * U * T = 64$ (Ameaça Alta)

Ameaça: Cross-Site Request Forgery (CSRF)
Impacto: o invasor pode induzir ao usuário logado a fazer ações sem que ele perceba podendo trocar dados das contas
Medidas: Validação e filtragem de dados inseridos pelos usuários e Atualização constantes do sistema e biblioteca
Gravidade (G) 4
Urgência (U) 4
Tendência (T) 3
GUT = $G * U * T = 48$ (Ameaça Alta)

Ameaça: Roubo de sessão (Session Hijacking)
Impacto: O invasor pode acessar cookie e token de sessão do usuário e invadir a conta do cliente sem precisar da senha
Medidas: Expiração automática da sessão após um tempo inativo, Uso obrigatório de HTTPS (Hypertext Transfer Protocol Secure)
Gravidade (G) 4
Urgência (U) 4

Tendência (T) 3

GUT = $G * U * T = 48$ (Ameaça Alta)

Ameaça: Phishing usando e-mails falsos da loja

Impacto: O invasor pode mandar e-mails falsos para os clientes se passando pela pet shop assim induzindo os clientes a clicarem em links falsos ou informar senhas e dados pessoais

Medidas: Implementar autenticação de e-mails, Monitoramento de tentativas suspeitas de login

Gravidade (G) 3

Urgência (U) 3

Tendência (T) 4

GUT = $G * U * T = 36$ (Ameaça Média)

Ameaça: Malware instalado no servidor

Impacto: Um malware pode infectar o servidor do site e permitir com que os invasores roubam dados dos clientes, altere páginas do site e instale vírus para os usuários

Medidas: Atualizações constantes do sistema e softwares do servidor, Firewall e bloqueio de portas desnecessárias

Gravidade (G) 5

Urgência (U) 4

Tendência (T) 4

GUT = $G * U * T = 80$ (Ameaça Crítica)

Ameaça: Ransomware (sequestro de dados)

Impacto: O ransomware pode criptografar os arquivos do servidor e do banco de dados da loja online impedindo o acesso aos pedidos e informações dos clientes

Medidas: Backups frequentes e armazenamentos em local seguro, Antivírus e monitoramentos de atividades suspeitas

Gravidade (G) 5

Urgência (U) 5

Tendência (T) 4

GUT = $G * U * T = 100$ (Ameaça Crítica)

Ameaça: Ataque DDoS (negação de serviço)

Impacto: O invasor pode sobrecarregar o site com muitas requisições ao mesmo tempo fazendo com que o site fique fora do ar

Medidas: Uso de firewall e proteção anti-DDoS, Monitoramento de tráfegos e bloqueio de IPs suspeitos

Gravidade (G) 3

Urgência (U) 4

Tendência (T) 3

GUT = G * U * T = 36 (Ameaça Media)

Ameaça: Senhas fracas dos usuários

Impacto: Usuários podem criar senhas simples facilitando ataques de invasão como força bruta ou vazamentos de credenciais

Medidas: Exigir senhas fortes (mínimo de caracteres, números e símbolos), Avisar usuários sobre segurança ao criar a senha

Gravidade (G) 3

Urgência (U) 3

Tendência (T) 4

GUT = G * U * T = 36 (Ameaça Media)

Ameaça: Credenciais de administrador vazadas

Impacto: Se o login e senha de um administrador forem vazadas um invasor pode acessar o painel administrativo do site e alterar preços, excluir produtos, acessar dados de clientes

Medidas: Autenticação de dois fatores para administradores, Senhas fortes e trocas periódicas

Gravidade (G) 5

Urgência (U) 5

Tendência (T) 4

GUT = G * U * T = 100 (Ameaça Crítica)

Ameaça: Configuração incorreta do servidor (portas abertas, permissões erradas)

Impacto: Se o site estiver mal configurado com portas abertas sem necessidade ou permissões erradas um invasor pode explorar essas falhas para acessar o sistemas, roubar informações do banco de dados ou instalar malware isso pode causar vazamentos de dados e comprometimento do funcionário do site

Medidas: Fechar portas desnecessárias e configurar firewall corretamente, Auditoria e verificação periódica de configurações

Gravidade (G) 4

Urgência (U) 4

Tendência (T) 3

GUT = G * U * T = 48 (Ameaça Alta)

Ameaça: API exposta sem autenticação adequada

Impacto: Se o site utilizar APIs e elas estiverem expostas sem autorização forte um invasor pode acessar ou alterar informações do sistemas como dados dos clientes, pedidos e estoque isso pode causar vazamento de dados e prejuízo financeiro

Medidas: Restringir acesso por permissões e níveis de usuários, Validação de entradas e proteção contra ataques automatizados

Gravidade (G) 4

Urgência (U) 4

Tendência (T) 4

GUT = $G * U * T = 64$ (Ameaça Alta)

Ameaça: Upload de arquivos maliciosos (ex: imagem com vírus)

Impacto: Caso o sistema permita envio de arquivos como fotos de perfil um invasor pode tentar enviar arquivos maliciosos disfarçados de imagens

Medidas: Restringir tipos de arquivos permitidos apenas PNG JPG por exemplo, Limitar tamanho do arquivo enviado

Gravidade (G) 4

Urgência (U) 4

Tendência (T) 3

GUT = $G * U * T = 48$ (Ameaça Alta)

Ameaça: Ataque Man-in-the-Middle (MITM) em conexão sem HTTPS

Impacto: Se o site não utilizar HTTPS corretamente um invasor pode interceptar a comunicação entre o usuário e o sistema capturando dados como email, senha e informações pessoais

Medidas: Uso obrigatório de HTTPS (SSL TLS) em todas as páginas, Redirecionamento automático de HTTP para HTTPS

Gravidade (G) 4

Urgência (U) 5

Tendência (T) 4

GUT = $G * U * T = 80$ (Ameaça Crítica)

Ameaça: Engenharia social contra suporte/atendimento

Impacto: Um invasor pode enganar funcionários do suporte se passando por um cliente tentando obter informações pessoais redefinir senhas ou alterar dados da conta

Medidas: Treinamento da equipe para identificar golpes e tentativas suspeitas, Uso de autenticação de dois fatores para redefinição de senha

Gravidade (G) 3

Urgência (U) 3

Tendência (T) 3

GUT = $G * U * T = 27$ (Ameaça Média)

Ameaça: Fraude em pedidos (compra com cartão roubado)

Impacto: Um invasor pode realizar compras usando cartões roubados ou dados clonados isso pode gerar prejuízo financeiros para a loja, chargebacks (estorno), perda de produtos enviados

Medidas: Integração com gateways de pagamentos seguros (ex PagSeguro, Mercado Pago, Stripe), Confirmação de identidades em compras de alto valor

Gravidade (G) 4

Urgência (U) 4

Tendência (T) 4

GUT = G * U * T = 64 (Ameaça Alta)

Ameaça: Roubo de dados durante integração com gateway de pagamento

Impacto: Durante a integração com o sistema de pagamento (gateway) se a comunicação ou implementação for insegura um invasor pode interceptar ou acessar informações relacionadas ao pagamento

Medidas: Utilizar gateways confiáveis e certificados (PagSeguro, Mercado Pago, Stripe etc), Monitorar logs de transações e tentativas suspeitas

Gravidade (G) 5

Urgência (U) 4

Tendência (T) 4

GUT = G * U * T = 80 (Ameaça Crítica)

Análise crítica exigida

A vulnerabilidade com maior nota GUT, tendo 100 de nota, foi a SQL Injection. Em um cenário real, um invasor poderia explorar essa falha através de campos de entrada do site, como busca de produtos, login ou formulário de cadastro. Ao inserir comandos SQL maliciosos nesses campos, o sistema poderia interpretar essas entradas como comandos válidos do banco de dados. Com isso, o atacante poderia acessar informações sensíveis, como nome, e-mail e endereço dos clientes, e até apagar ou alterar registros do sistema.

Para mitigar esse risco, o grupo adotará como solução técnica o uso de consultas parametrizadas (Prepared Statements) e uso de ORM (Object-Relational Mapping) no backend, evitando que dados inseridos pelo usuário sejam interpretados como comandos SQL. Além disso, será aplicado validação e sanitização de inputs, controle de permissões no banco de dados e monitoramento de logs para identificar tentativas suspeitas. Dessa forma, o risco de SQL Injection é reduzido de forma significativa.

Adequação à LGPD

Nome completo

Finalidade: Identificar o cliente no cadastro e nos pedidos

Base legal: Execução de contrato (Art. 7º, V)

Direitos do titular: Editar no perfil ou solicitar exclusão

Email

Finalidade: Login, comunicação e confirmação de compra

Base legal: Execução de contrato (Art. 7º, V)

Direitos do titular: Editar no perfil ou solicitar exclusão

Senha

Finalidade: Autenticação e acesso à conta

Base legal: Execução de contrato (Art. 7º, V)

Direitos do titular: Pode redefinir senha ou excluir conta

Endereço completo

Finalidade: Entrega dos produtos comprados

Base legal: Execução de contrato (Art. 7º, V)

Direitos do titular: Pode editar ou solicitar exclusão

Número de telefone

Finalidade: Contato em caso de problemas com entrega ou com o pedido

Base legal: Execução de contrato (Art. 7º, V)

Direitos do titular: Pode editar ou solicitar exclusão

CPF

Finalidade: Emissão de nota fiscal

Base legal: Cumprimento de obrigação legal (Art. 7º, II)

Direitos do titular: Pode solicitar correção ou exclusão quando permitido por lei

Histórico de pedidos

Finalidade: Controle de compras e suporte ao cliente

Base legal: Execução de contrato (Art. 7º, V)

Direitos do titular: Pode solicitar acesso e exclusão conforme prazos legais

Dados de pagamentos (token de gateway)

Finalidade: Processar pagamento no checkout

Base legal: Execução de contrato (Art. 7º, V)

Direitos do titular: Pode solicitar exclusão após finalizar o pedido

IP do usuário

Finalidade: Segurança, prevenção de fraude e auditoria

Base legal: Legítimo interesse (Art. 7º, IX)

Direitos do titular: Pode solicitar informações e exclusão conforme política

Cookies essenciais

Finalidade: Manter sessão ativa e carrinho de compras

Base legal: Execução de contrato (Art. 7º, V)

Direitos do titular: Pode limpar cookies no navegador ou sair da conta

Cookies de marketing

Finalidade: Anúncios personalizados e campanhas

Base legal: Consentimento (Art. 7º, I)

Direitos do titular: Pode desativar no site e revogar consentimento

Dados de navegação

Finalidade: Melhorar a experiência e entender comportamento de compra

Base legal: Consentimento (Art. 7º, I) ou legítimo interesse (Art. 7º, IX)

Direitos do titular: Pode solicitar exclusão e desativar rastreamento

Dados de carrinho

Finalidade: Permitir salvar itens antes da compra

Base legal: Execução de contrato (Art. 7º, V)

Direitos do titular: Pode apagar carrinhos ou excluir conta

Data e hora de login

Finalidade: Auditoria e segurança contra invasões

Base legal: Legítimo interesse (Art. 7º, IX)

Direitos do titular: Pode solicitar relatório e exclusão quando aplicável

Endereço de entrega alternativo

Finalidade: Entregar em outro local solicitado pelo cliente

Base legal: Execução de contrato (Art. 7º, V)

Direitos do titular: Pode editar ou remover do perfil

Nome do responsável pela entrega (destinatário)

Finalidade: Garantir recebimento correto da encomenda

Base legal: Execução de contrato (Art. 7º, V)

Direitos do titular: Pode alterar ou excluir antes do envio

Avaliação/comentário de produtos

Finalidade: Permitir feedback e reputação da loja

Base legal: Consentimento (Art. 7º, I)

Direitos do titular: Pode editar ou excluir avaliação

Atendimento de suporte

Finalidade: Resolver problemas e dúvidas do cliente

Base legal: Execução de contrato (Art. 7º, V)

Direitos do titular: Pode solicitar acesso e exclusão

Dados de nota fiscal

Finalidade: Registro fiscal obrigatório

Base legal: Cumprimento de obrigação legal (Art. 7º, II)

Direitos do titular: Pode solicitar correção (quando possível) e acesso

Newsletter e promoções

Finalidade: Envio de ofertas e marketing

Base legal: Consentimentos (Art. 7º, I)

Direitos do titular: Pode cancelar inscrição e solicitar exclusão